JANET'S QUALITY CATERING

System Workflow

How users, modules and data work together, as implemented.

System	Catering management system (PHP and MariaDB)
Database version	2.8.0 (janets_catering)
Date	November 7, 2026
Intended readers	Project reviewers, administrators and future developers

Contents

1. System overview
2. System objectives
3. User roles and permissions
4. Login and authentication workflow
5. Account management workflow
6. Event booking, payments, attachments and SOA
7. Client records workflow
8. Supervisor dashboard workflow
9. Client survey workflow
10. Profile management workflow
11. Dashboard workflow
12. Reports management workflow
13. Archiving and automatic deletion workflow
14. Overall system workflow
15. Interaction between modules
16. Explanation of shared processes

1. System overview

Janet's Quality Catering is a web system for running a catering business. Staff record event bookings, manage menus and food stocks, collect client feedback, write reports, and manage staff accounts. It runs on PHP 8.2 and MariaDB 10.4 under XAMPP on one computer, and is used through a web browser.

Part	What it does	Main file
Dashboard	Live summary of bookings and revenue	`dashboard.php`
Event Bookings	Four-step booking wizard, statuses, payments, attachments, Statement of Account, archive, print and PDF	`event_bookings.php`
Client Surveys	Ratings by criterion, from the client's link or entered by staff	`surveys.php`
Client Records	One record per client, with full booking history	`clients.php`
Supervisor Dashboard	Event preparation view with no financial information	`supervisor_dashboard.php`
Backdrops, Food Menus	Catalogue records	`backdrops.php`, `food_menus.php`
Accounts	Create, deactivate, archive, remove credentials	`accounts.php`
Reports	Create, edit, archive, print and PDF	`reports.php`
Activity Log and Notifications	Automatic record of every change, and alerts	`activitylog.php`, `notifications.php`
Backup & Restore	Database backups, verification and restore	`backups.php`
Profile	Own details, password and photo	`profile.php`
Scheduled clean-up	Deletes expired archived records every hour	`cli/maintenance_cli.php`

2. System objectives

- Keep one accurate record of each event booking from request to archive.
- Show managers the current state of the business without reloading pages.
- Collect structured client feedback on food, service, timeliness, setup and value.
- Control who can sign in and what each role can do, checked on the server for every request.
- Record every change automatically so that actions can be traced.
- Keep archived bookings and reports for 30 days, then remove them without anyone having to remember.
- Reject bad data at the form and again at the server: names, Philippine mobile numbers, postal codes and uploads.

3. User roles and permissions

The system has three roles: OWNER, ADMIN and SUPERVISOR. Clients have no accounts: they use a private survey link only. New accounts get the ADMIN role, except that the Owner may create a Supervisor.

Module	ADMIN	OWNER	SUPERVISOR
Dashboard	Full	Full	No access
Event Bookings, payments, attachments, Statement of Account	Full	Full	No access
Event Bookings Dashboard	No access	No access	View only, with no financial information
Client Records	Full	Full	No access
Accounts	No access	Full, except own account	No access
Reports	Full	Full	No access
Client Surveys	Full	Full	No access
Backdrops	Full	Full	No access
Food Menus	Full	Full	No access
Notifications	Own only	Own only	No access
Activity Log	View and search only	View, search, archive and restore entries	No access
Backup & Restore	Full	No access	No access
Profile	Own only	Own only	Password change on the dashboard only
Eye icon to hide amounts	None: amounts always visible	Yes	Not applicable

> **Two deliberate differences.** Backup & Restore stays ADMIN only and Activity Log management stays OWNER only, as set by the earlier role requirements. Admin and Owner are otherwise the same, except that only the Owner manages Supervisors and can hide amounts.

How permissions are enforced

- `includes/auth_check.php` runs first on every protected page and sends anyone not signed in to the login page, so typing a URL directly does not bypass it.
- It re-reads the account from the database on every request. An account that was deleted, archived, deactivated or unverified loses its session at once.
- A Supervisor is stopped at the same point: every page and endpoint other than the Event Bookings Dashboard is refused, whatever URL is typed.
- `jq_require_roles()` checks the role stored in the database, not the one in the session. A refusal is written to the Activity Log.
- Every POST must carry the session's security token, whether it comes from a form or from a background request.

4. Login and authentication workflow

Signing in takes two steps: the password, then a 6-digit code sent to the account's Gmail address. The Terms and Conditions must be accepted on the first page, where clicking those words opens the terms window. The code page does not ask again.

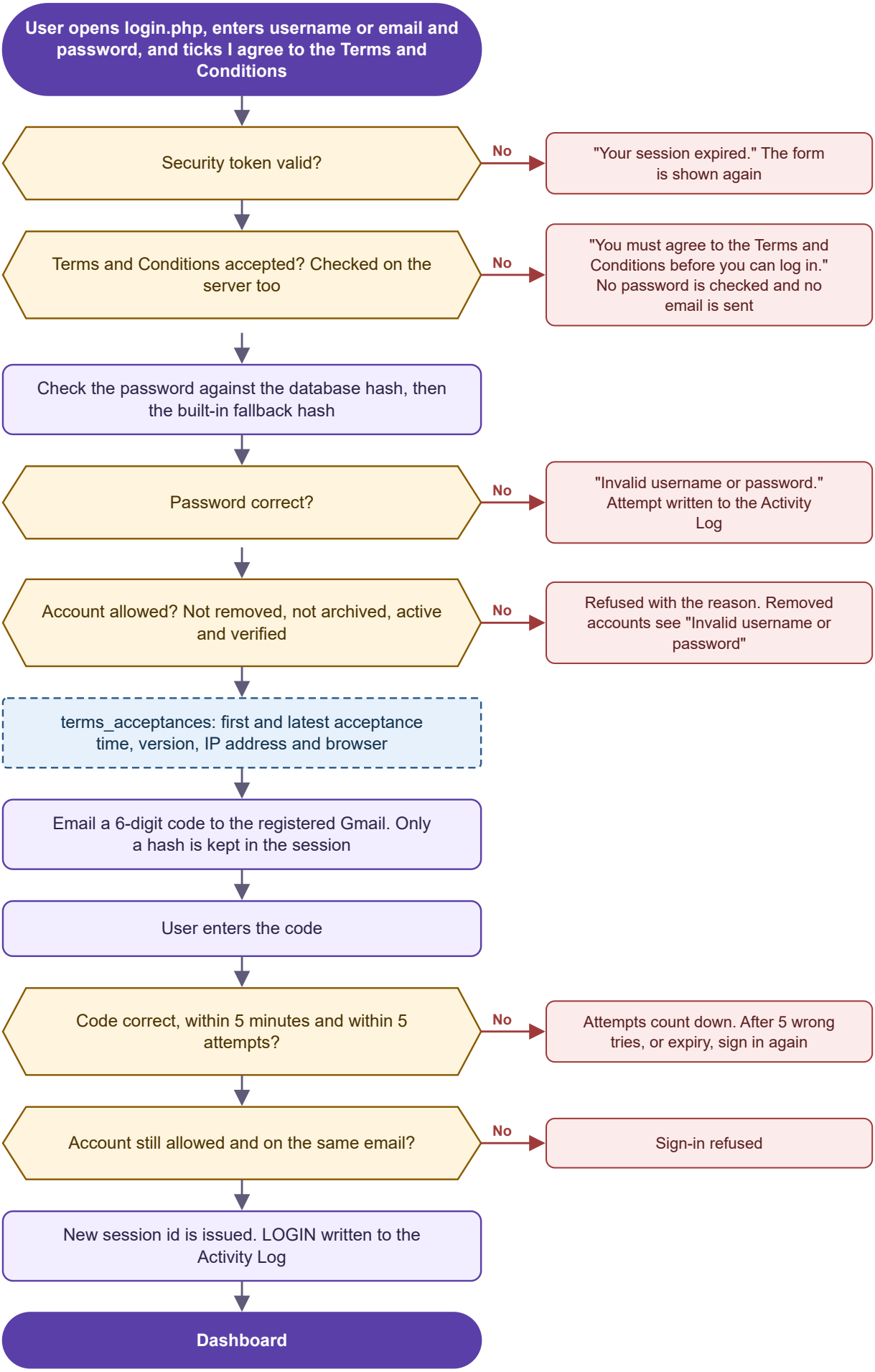

User opens login.php, enters username or email and password, and ticks I agree to the Terms and Conditions
Security token valid?
No
"Your session expired." The form is shown again
Terms and Conditions accepted? Checked on the server too
No
"You must agree to the Terms and Conditions before you can log in." No password is checked and no email is sent
Check the password against the database hash, then the built-in fallback hash
Password correct?
No
"Invalid username or password." Attempt written to the Activity Log
Account allowed? Not removed, not archived, active and verified
No
Refused with the reason. Removed accounts see "Invalid username or password"
terms_acceptances: first and latest acceptance time, version, IP address and browser
Email a 6-digit code to the registered Gmail. Only a hash is kept in the session
User enters the code
Code correct, within 5 minutes and within 5 attempts?
No
Attempts count down. After 5 wrong tries, or expiry, sign in again
Account still allowed and on the same email?
No
Sign-in refused
New session id is issued. LOGIN written to the Activity Log
Dashboard

Figure 1. Login

Session rules

- The cookie is HttpOnly and SameSite=Lax, and marked Secure when the site runs on HTTPS.
- Session ids the server did not create are refused.
- A session ends after 30 minutes without activity. Mouse, keyboard, scrolling and touch count, in any open tab, and the browser reports them to the server at most once a minute. Two minutes before the end a warning offers Stay signed in. The server ends the session on its own if the browser never reports.
- Logging out asks for confirmation from the header menu, records LOGOUT, destroys the session and removes its cookie. An automatic sign-out is recorded with the reason.

5. Account management workflow

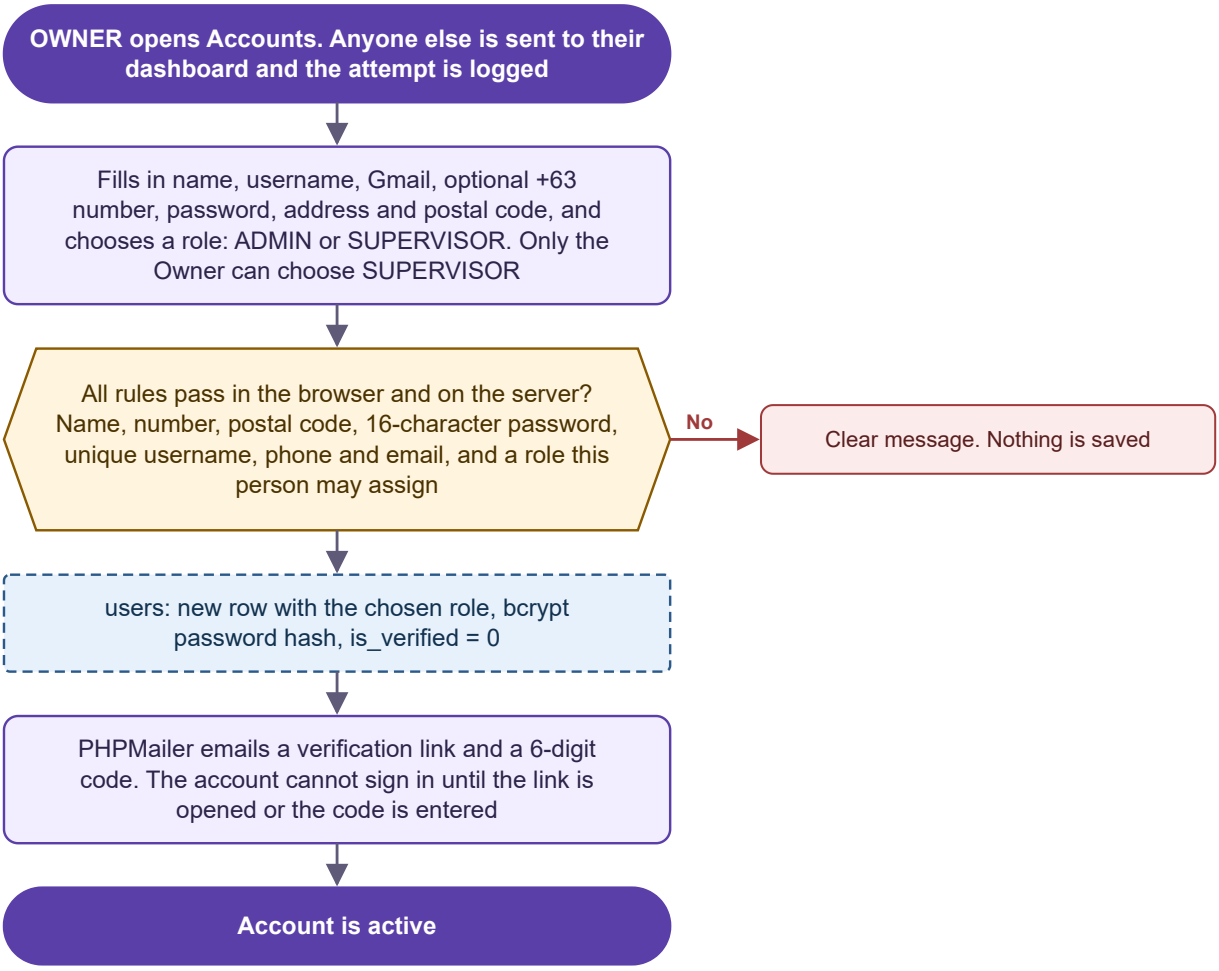


Figure 2. Creating an account

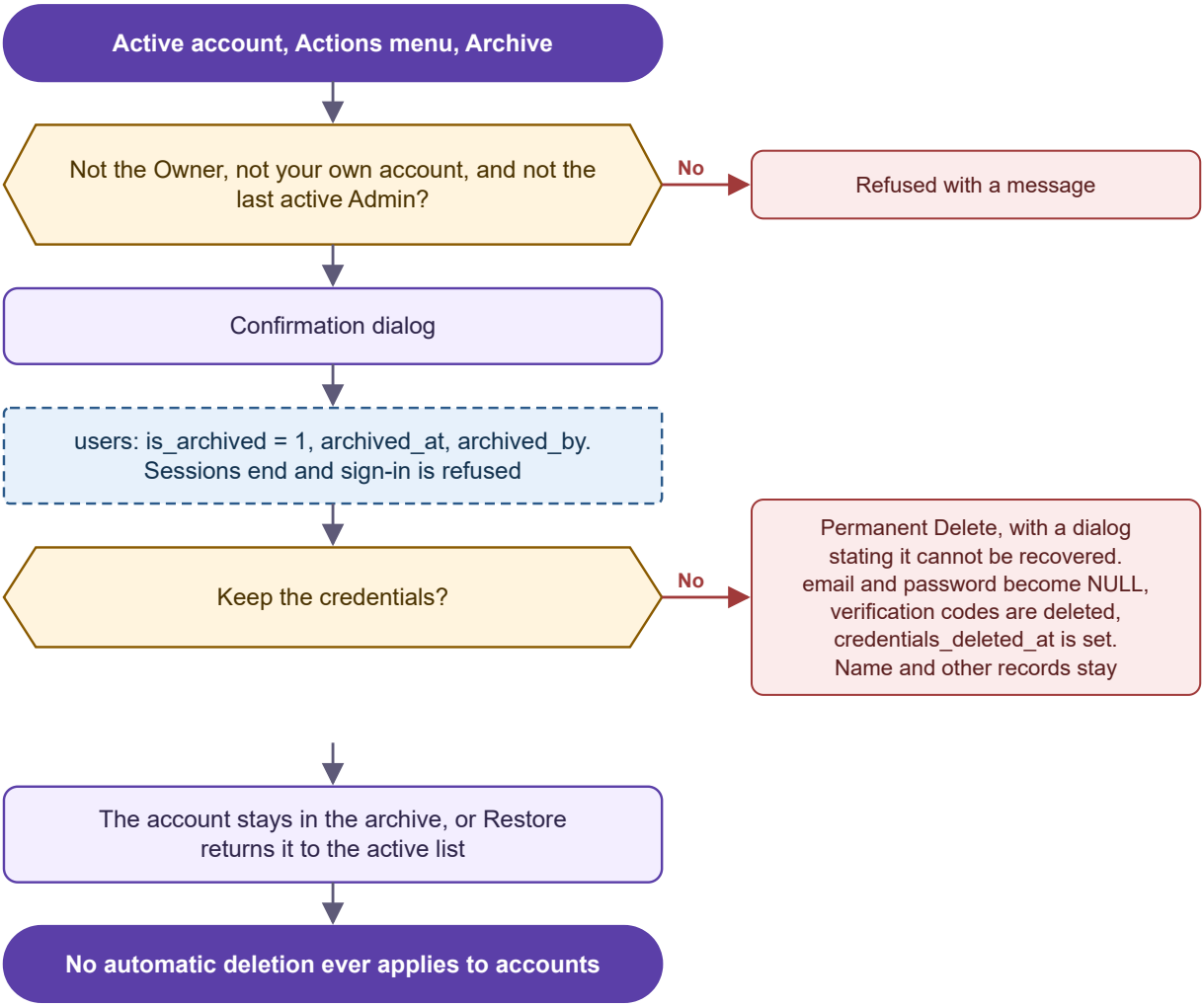


Figure 3. Archiving an account and removing its credentials

Restoring an archived account

Accounts is Owner only: the menu item is hidden from other roles, and the server refuses the page and all of its forms for them. The Owner archives an account from its Actions menu and restores it with the Restore button in the Archive section. A restored account returns to the active list. An account whose credentials were permanently removed cannot be restored.

Creating a Supervisor

A link and a 6-digit code go to the Supervisor's Gmail. Only hashes are stored. Both expire after 30 minutes and stop working once used or replaced by a newer email; the code also stops after 5 wrong tries. An expired link offers a new one, sent only to the account's own address. Links are built from `APP_BASE_URL` in `config/email_config.php`, never from the request. The account cannot sign in until it is verified. The Owner can deactivate and reactivate it, and only the Owner can change it.

Custom event types

Choosing **Others** in the booking form opens a field with an **Add Event Type** button. It uses the same save as the Add Event Type button on the Event Bookings Dashboard. The new type joins the dropdown at once and stays for future bookings. The same name in any letter case is not added twice, and "Others" itself cannot be saved. A custom type is offered all backdrops, since it has no gallery of its own.

Printing and backdrops

Each booking's Actions menu has **Print / Save as PDF**, which prints that booking alone with the logo, client, event, selected backdrop, inclusions and payments. PDF is chosen in the browser's print dialog. Supervisors see each booking's backdrop as a picture in their table and details window, read from the booking record, and can print those details, which hold no prices. A booking saved without a backdrop shows "Not recorded".

After Permanent Delete the account can never sign in or be restored, including through the built-in fallback password, and its email address is free for a new account.

6. Event booking workflow

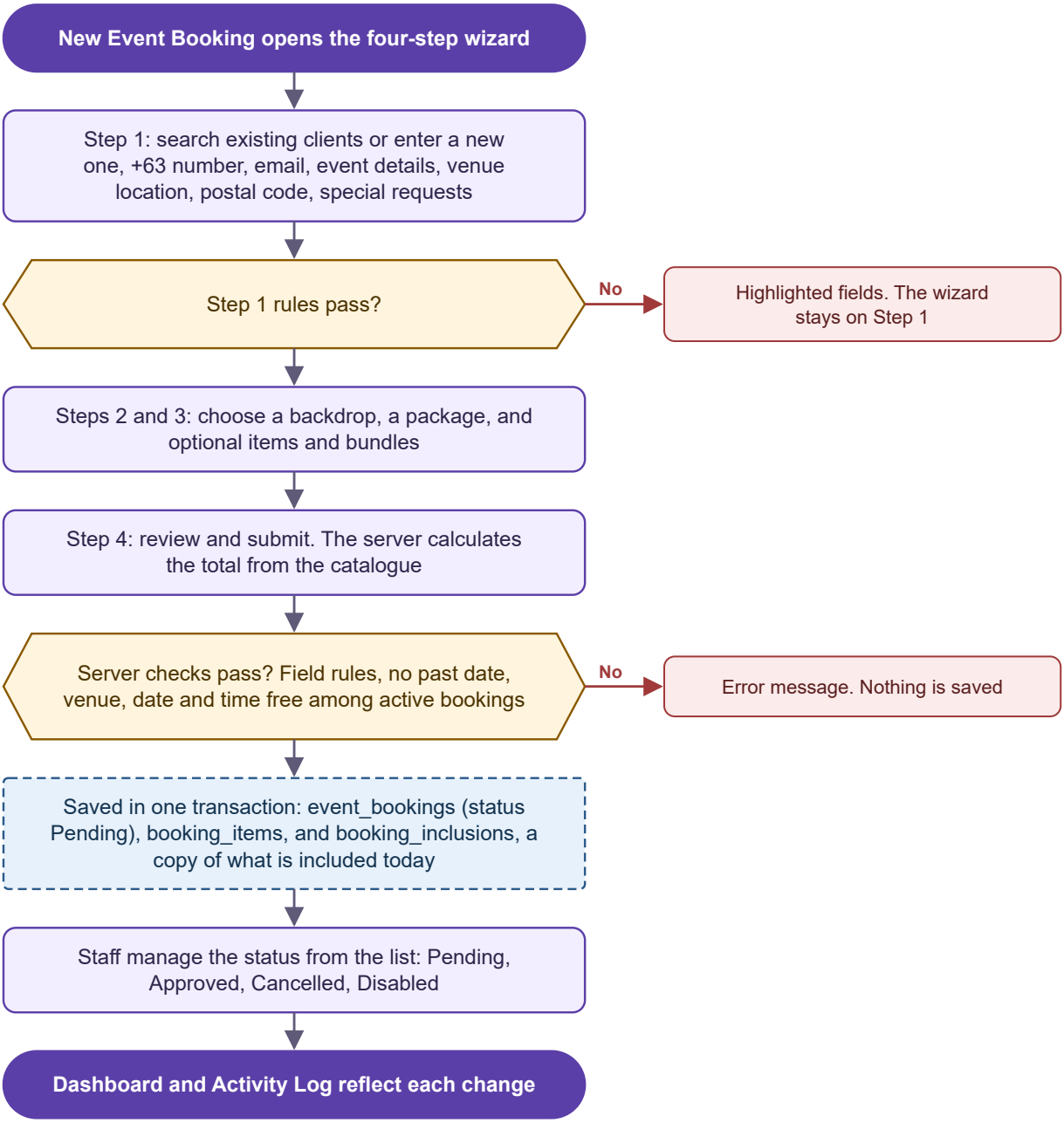


Figure 4. Creating a booking

Status	Meaning	Counts as active	Holds the venue slot
Pending	Waiting for approval	Yes	Yes
Approved	Confirmed to go ahead	Yes	Yes
Completed	The event finished. Set only with the Completed button, which also saves the date and the client record	No	No
Cancelled	Will not proceed. Also set automatically on archiving	No	No
Disabled	Set aside, not treated as active	No	No

The main list opens on active bookings. Cancelled and Disabled have their own tiles and filter options. A booking cannot move back to Pending or Approved if another active booking now holds its venue, date and time.

Payments

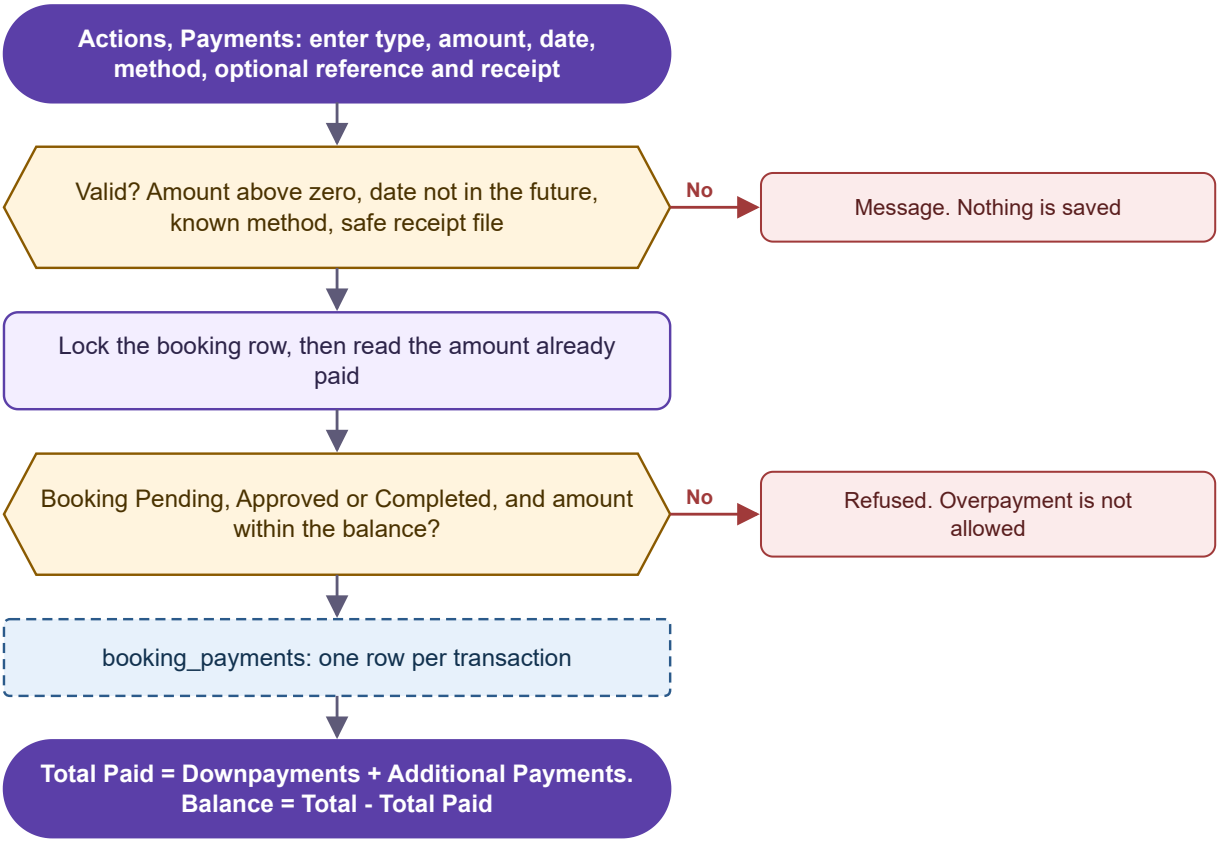


Figure 4a. Recording a payment

Payment status	Meaning
Unpaid	Nothing recorded
Partially Paid	Some recorded, balance remains
Awaiting Proof of Payment	Full amount recorded, but at least one payment has no receipt
Payment Pending Verification	Full amount recorded with receipts, but not all are verified
Fully Paid	Verified receipts cover the whole total, event not completed yet
Settled	Verified receipts cover the whole total and the event is Completed

Proof of payment

An amount alone never makes a booking Fully Paid. Each payment moves through Awaiting Receipt, Receipt Submitted (uploaded, not yet opened), Pending Verification (opened by an Admin or the Owner) and Verified, or Rejected. Verify only works after the receipt was opened. Rejecting needs a reason and asks for a replacement; the replacement is uploaded on the same payment and the rejected receipt moves to payment_receipt_history with its review. Who reviewed each receipt and when is saved. Only an entry

with no receipt can be deleted. Mark as Completed needs the payment to be Fully Paid; until then it shows disabled, and the server refuses it.

Supervisor and payments

The Supervisor sees each event's payment status under its preparation status and in the event details, read only. No amounts are sent to that page, and every payment or completion request from a Supervisor is refused.

These figures are calculated from the transactions each time and are not stored. Editing a booking so that its total falls below the amount paid is refused.

Attachments and Statement of Account

Contracts, signatures and approval documents are uploaded per booking as PDF, image, DOC or DOCX, up to 10 MB. Files and receipts sit in a folder that refuses direct requests, and are sent only after a role check. Generate SOA opens a printable statement with Print and Download PDF, built from the actual transactions.

Completing an event

The Completed button asks for confirmation, saves the date, and connects the booking to a client record. It never changes payments.

Client records workflow

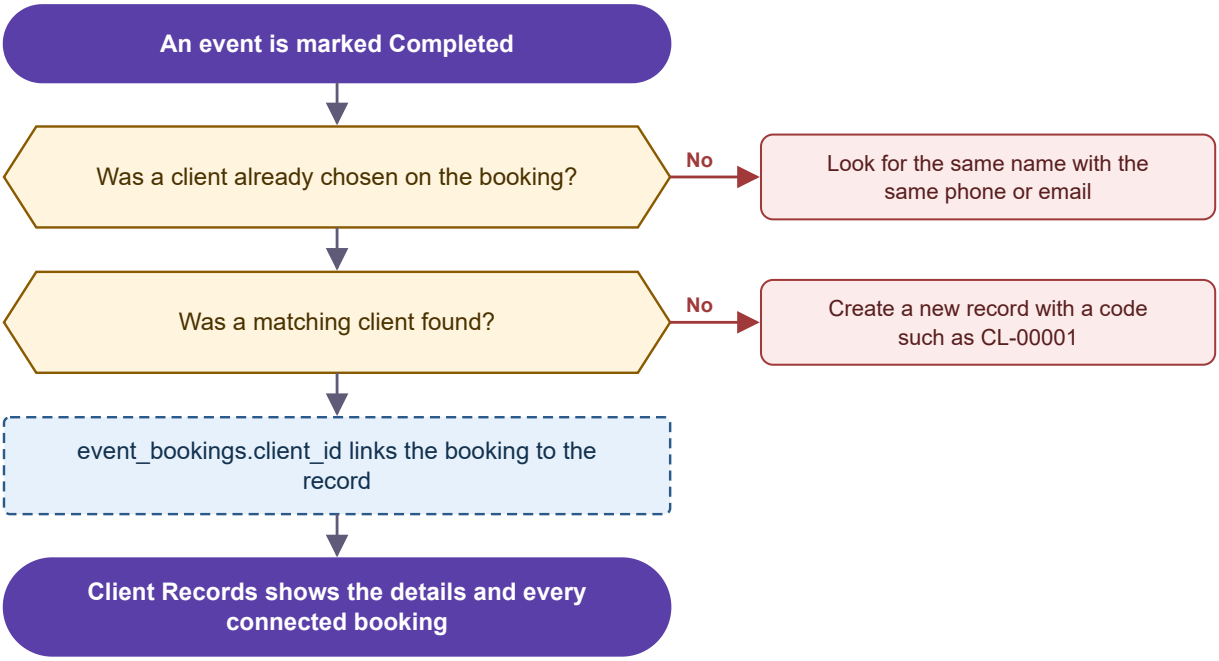


Figure 4b. Saving a client

When a client books again, staff search for them in Step 1, or the system links an exact match on saving. Each booking stays its own record, so a client can have a Wedding in January and a Birthday in December. Updating a client's details does not change past bookings.

Supervisor dashboard workflow

The Supervisor sees five counts, a month calendar, and a preparation table: booking reference, client, event type, date, guests, package, food inclusions, add-ons, backdrop and setup, and preparation status. View opens everything needed to prepare, including every inclusion and the notes.

The page names each database column it reads, and none is a price, total or payment. Preparation status and notes are set by the Owner or Admin in the booking window.

7. Client survey workflow

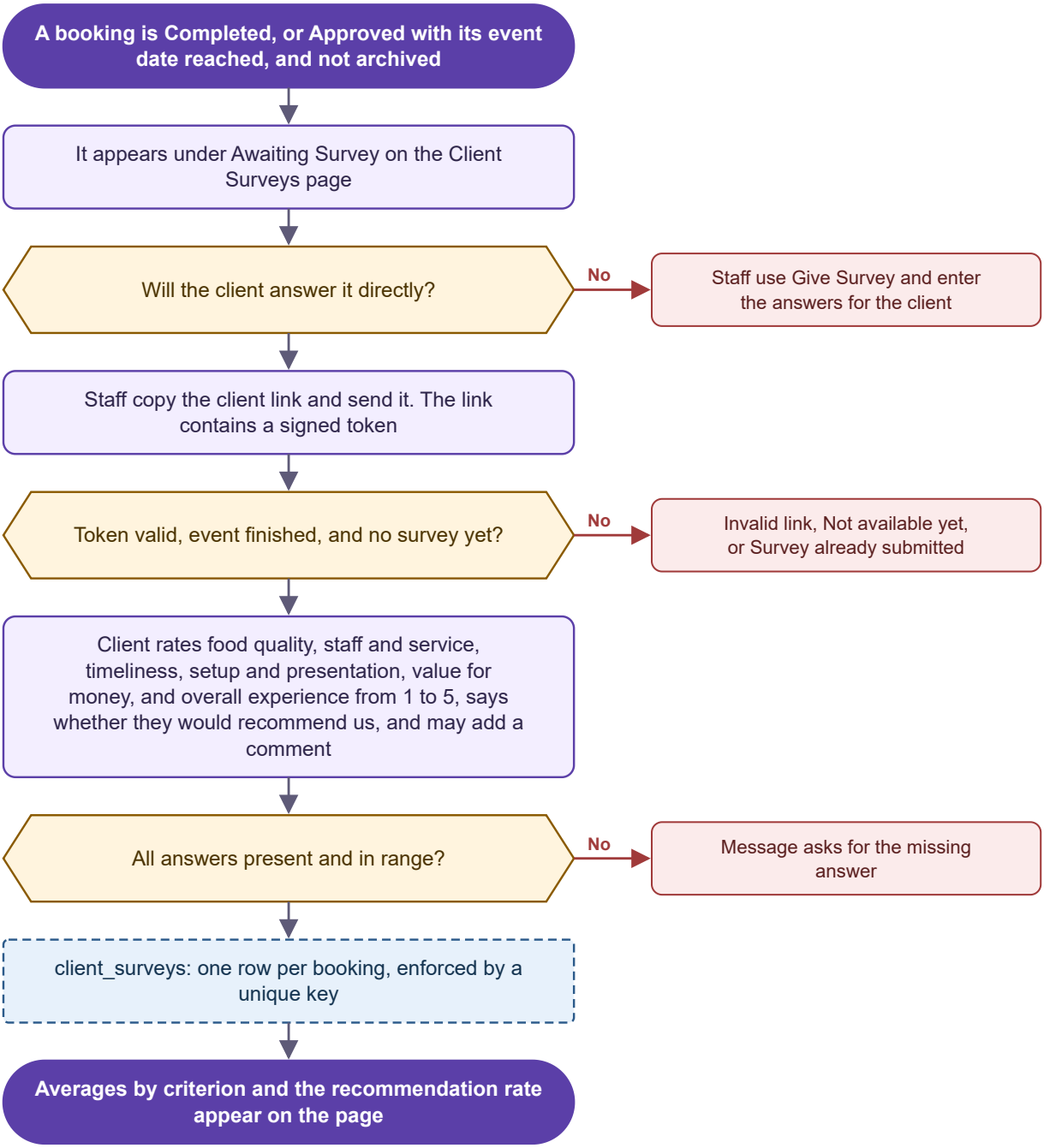


Figure 5. Client survey

All survey icons share one colour and all stars share another, in both light and dark mode. On the client page icons measure 7.7:1 against white, filled stars 5.0:1 and unfilled stars 3.2:1.

8. Profile management workflow

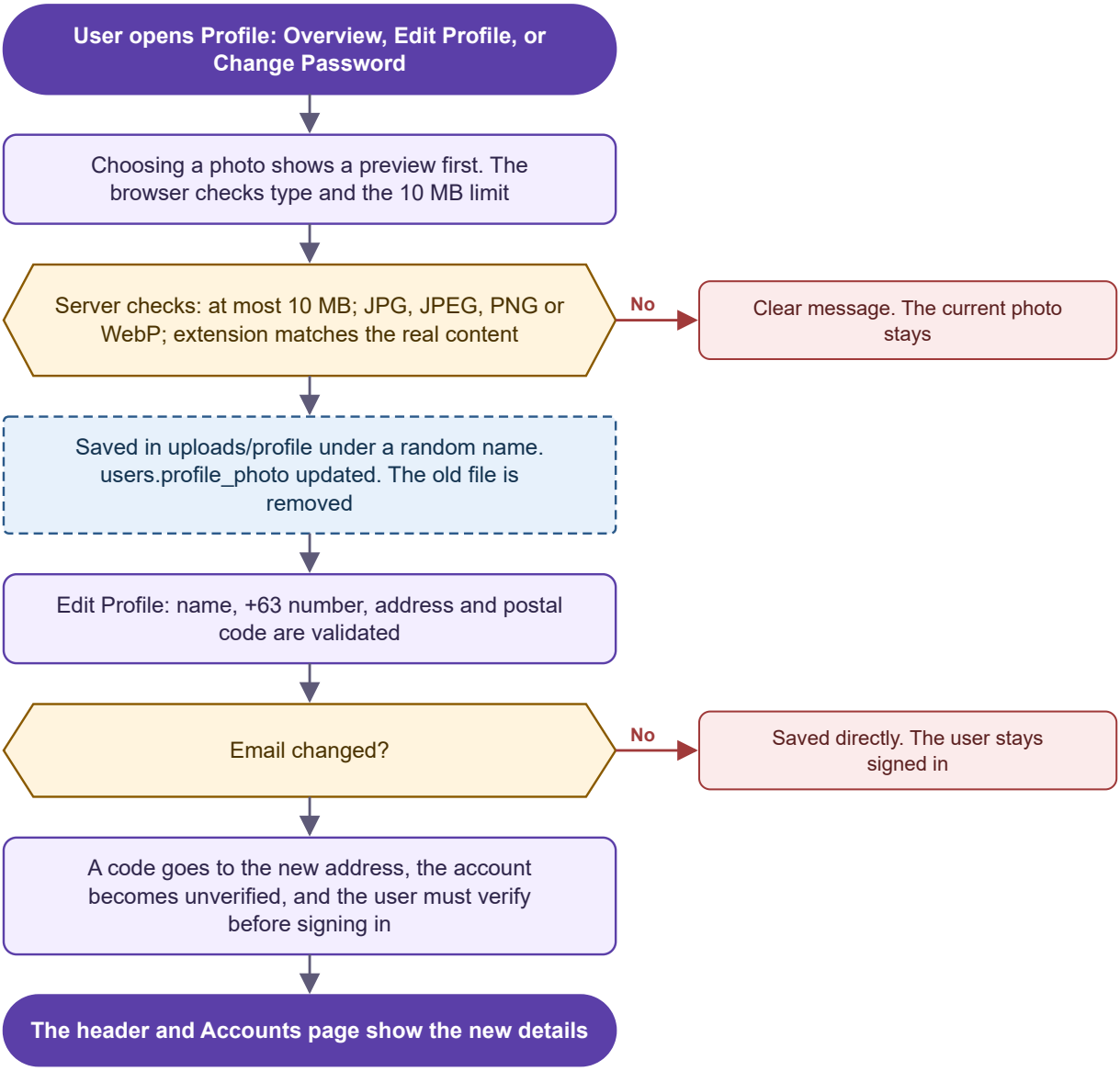


Figure 6. Profile

Changing a password requires the current password, a new one of at least 16 characters, and a matching confirmation.

9. Dashboard workflow

The dashboard has no booking data of its own. Each time, `includes/dashboard_data.php` reads `event_bookings` directly.

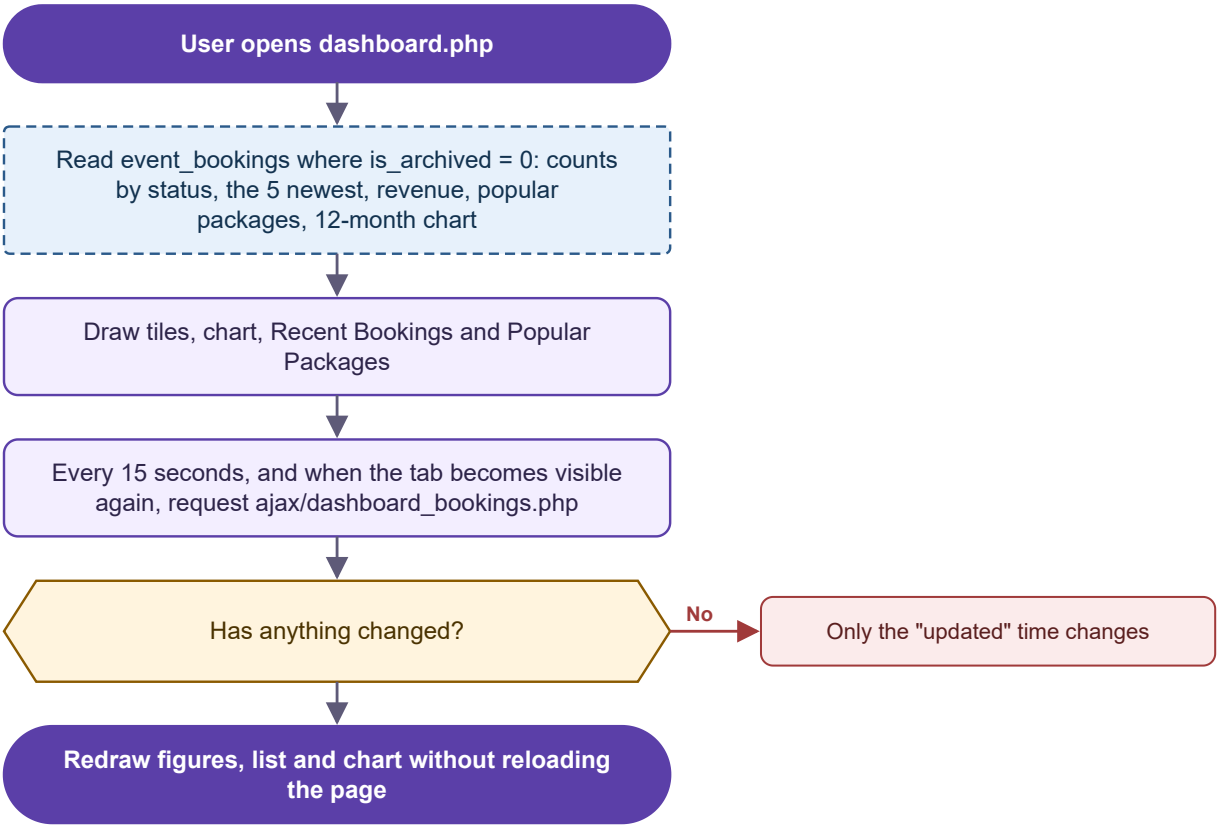


Figure 7. Dashboard refresh

- **Active Bookings** counts Pending and Approved only. Cancelled and Disabled are shown separately.
- **Recent Bookings** shows the five newest bookings that are not archived, with their current status.
- Archived and permanently deleted bookings appear in no count, list or total. Revenue counts active bookings only.

10. Reports management workflow

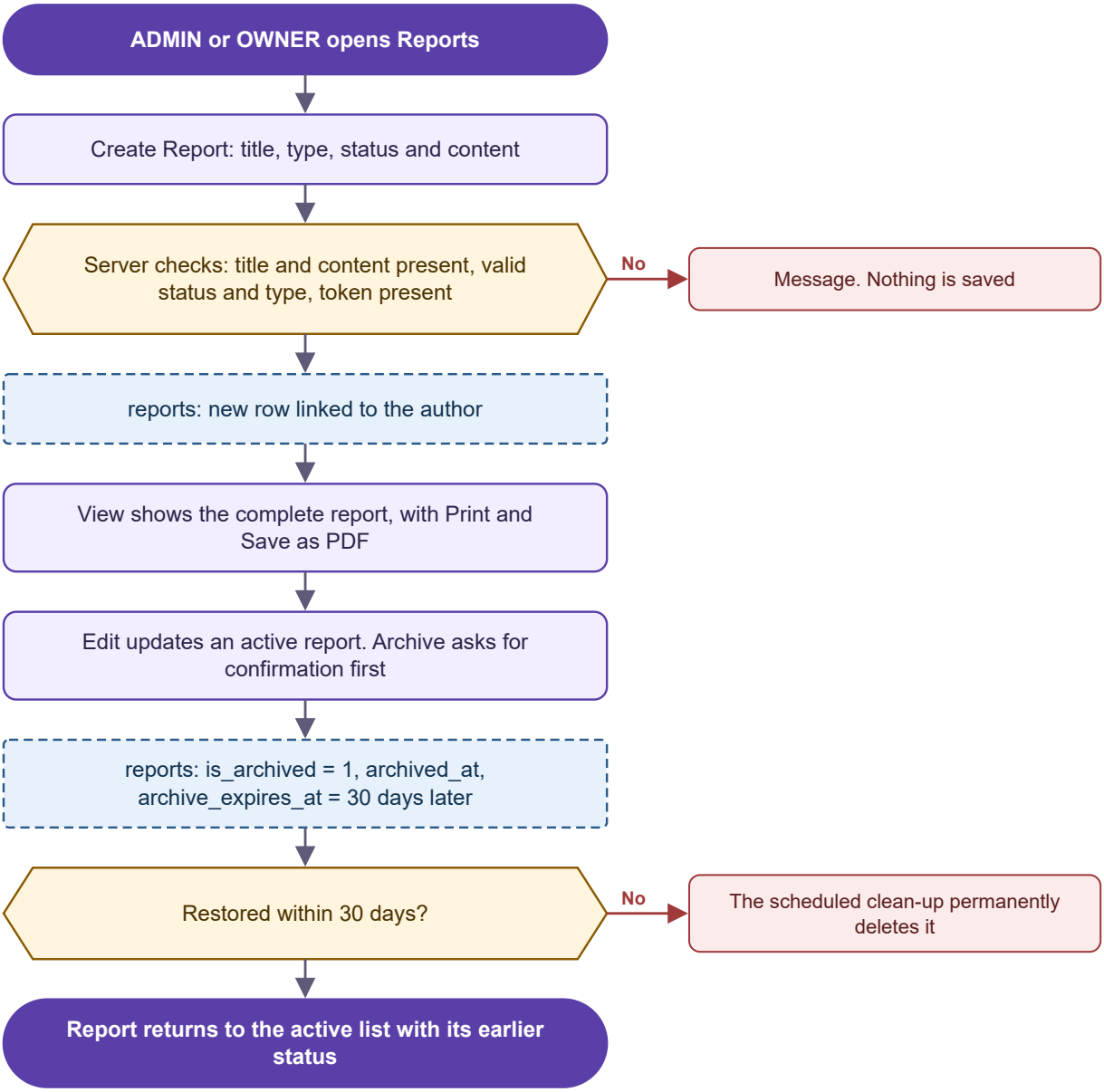


Figure 8. Reports

Print uses the browser's print function with fixed light colours. Save as PDF builds a real text PDF in the browser, with the title, report ID, type, status, author, dates, content and page numbers. Its library is stored in the project, so it works without internet.

11. Archiving and automatic deletion workflow

Record	Archive action	After 30 days	Restore
Event booking	Status becomes Cancelled, earlier status is stored, deletion date is set	Permanently deleted	Returns to its earlier status, or Cancelled if the slot is taken
Report	Deletion date is set	Permanently deleted	Returns unchanged
Account	Cannot sign in	Never deleted automatically	Allowed unless credentials were removed

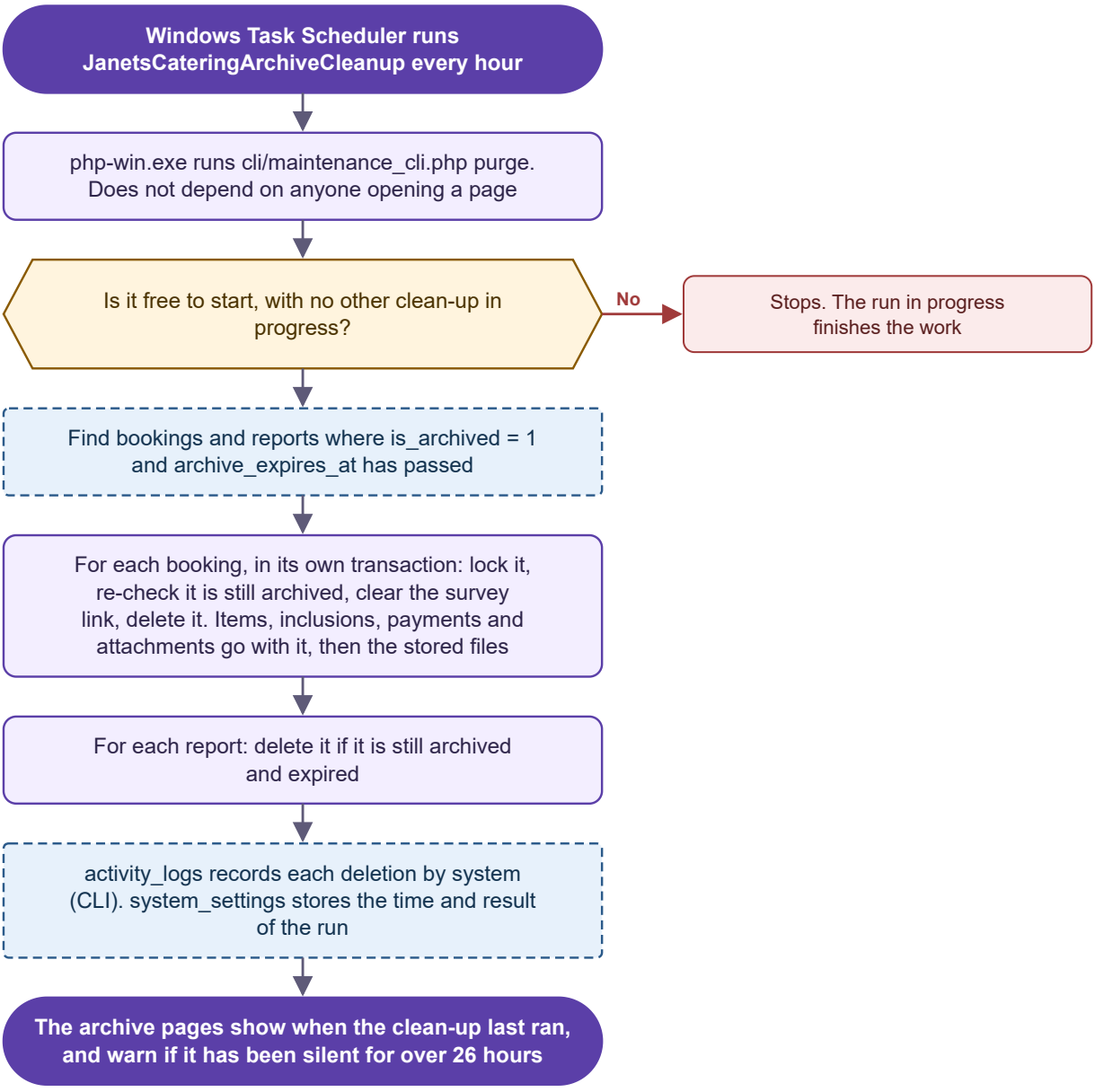


Figure 9. Automatic deletion

Staff may also delete an archived booking by hand with Delete, after a confirmation. A record restored while the clean-up is running is left alone.

12. Overall system workflow

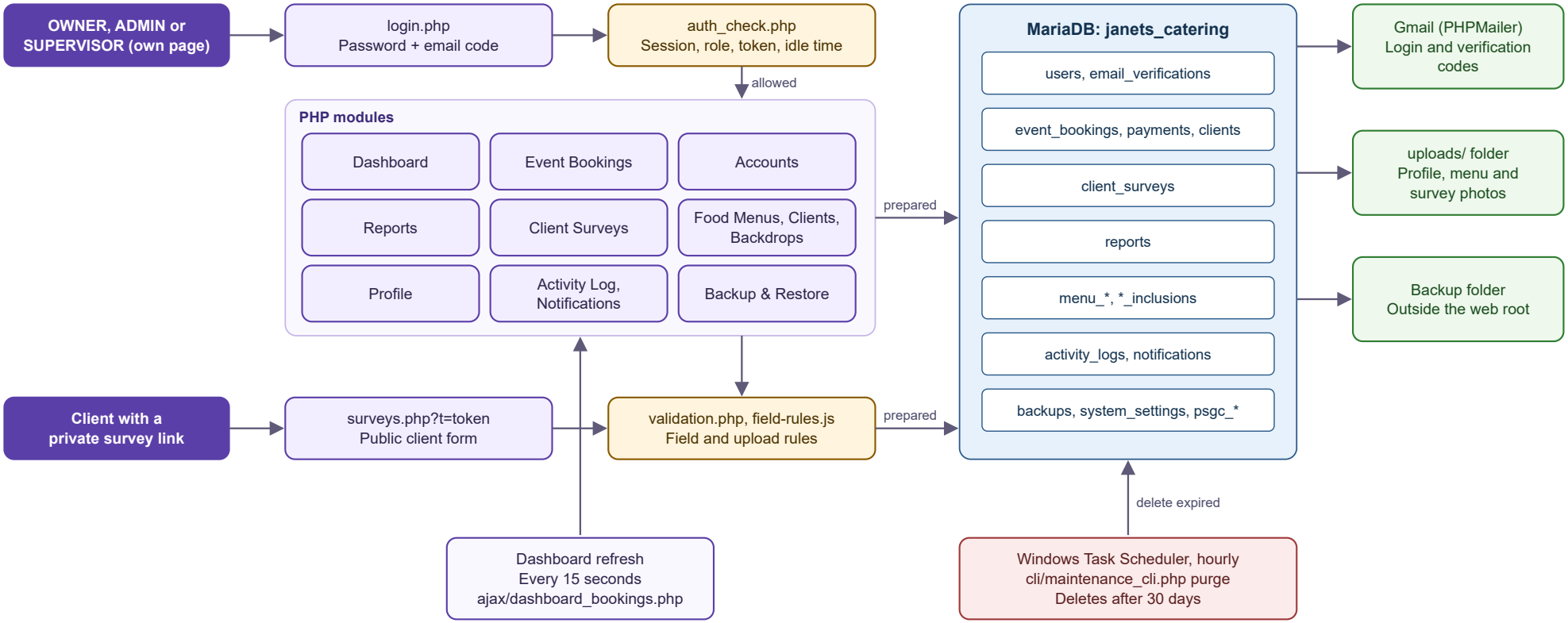


Figure 10. How requests and data move through the system

Staff reach a module only after login and the checks in `auth_check.php`. Clients reach only the survey form. All modules read and write one database. Email, photo storage, backups and the scheduled clean-up sit around it.

13. Interaction between modules

From	To	What passes between them
Accounts	Login, every page	Status, archive state and role decide access on each request
Event Bookings	Dashboard	Counts, list, revenue and chart are read live from the same table
Event Bookings	Client Surveys	An Approved booking whose date has arrived opens a survey. Names and date are copied to the survey
Backdrops	Event Bookings	A chosen backdrop is carried into the wizard
Food Menus	Event Bookings	Packages, items and bundles offered in the wizard. Names and prices are copied to the booking
Event Bookings	Client Records	Completing a booking creates or links the client. Returning clients are found when booking
Food Menus	Supervisor Dashboard	Inclusions are copied to each booking and shown from that copy, with no prices
Every module	Activity Log	Database triggers record each create, update, archive, restore and delete
Activity Log	Notifications	One notification per active, verified, non-archived Admin or Owner for each important event
Scheduled clean-up	Bookings, Reports, Surveys	Deletes expired records and clears survey links, leaving the surveys
Login, Accounts, Profile	Gmail (PHPMailer)	Login codes, verification links and codes
Backup & Restore	Whole database	Copies all tables. After a restore, older backups are upgraded automatically to the current structure

14. Explanation of shared processes

Process	How it works
Field validation	`static/js/field-rules.js` checks as you type and blocks submission. `includes/validation.php` repeats each rule on the server, so a request that skips the browser is still refused.
Names	The letters A to Z and single spaces. Numbers and symbols cannot be typed or pasted.
Contact numbers	The form shows a fixed +63 and takes 10 digits. The first digit must be 9. Other digits, letters and symbols cannot be typed or pasted. Stored as `+639XXXXXXXXX`, displayed as +63 9123456789.
Postal codes	Exactly 4 digits. Required on accounts and bookings.
Security token	`includes/header.php` adds the token to every form and same-site request. `includes/auth_check.php` refuses any POST without it.
Passwords	Stored with `password_hash()` and checked with `password_verify()`.
Database writes	All use prepared statements. Multi-step changes, such as a booking with its items, use transactions.
Activity logging	Generated database triggers record who, when, and the old and new values. Passwords and account emails are masked.